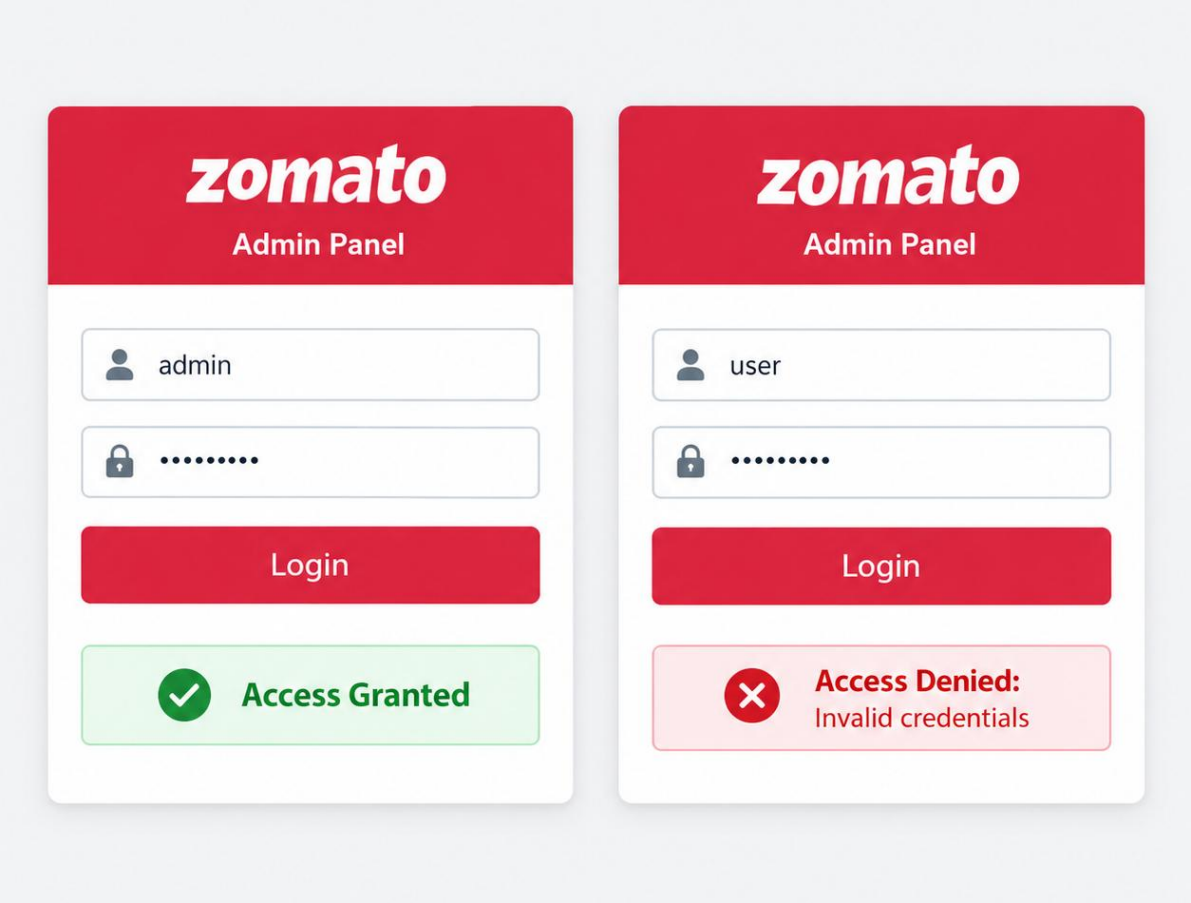
Assignment – 2.3

Authentication and Access Control

Q - 1. Create a simple login form for a mock Zomato admin panel that asks for username and password, then displays 'Access Granted' only if both fields match hardcoded admin credentials.



Q - 2. Write a Python function check_access(user_role, resource) that returns True if the user_role is allowed to access the resource, otherwise False. Test it with roles like 'customer', 'restaurant_owner', and resources like 'menu_edit', 'order_history', 'admin_dashboard'. Hint: Use a dictionary to map roles to allowed resources.

- **Python Program: Role-Based Access Control:**

```
def check_access(user_role, resource):
    # Dictionary mapping roles to allowed resources
    permissions = {
        "customer": ["order_history"],
        "restaurant_owner": ["menu_edit", "order_history"],
        "admin": ["menu_edit", "order_history", "admin_dashboard"]
    }

    # Check whether the resource is allowed
    return resource in permissions.get(user_role, [])

# Test cases
print(check_access("customer", "order_history"))
```

```
print(check_access("customer", "menu_edit"))
print(check_access("restaurant_owner", "menu_edit"))
print(check_access("restaurant_owner", "admin_dashboard"))
print(check_access("admin", "admin_dashboard"))
```

- **Output:**

```
True
False
True
False
True
```

Q - 3. Simulate a two-factor authentication flow like Paytm: after a user enters the correct password, generate a 6-digit OTP and display it in the console. Ask the user to input the OTP and display 'Login Successful' only if it matches.

- **Python Program for Two-Factor Authentication (2FA):**

```
import random

password = "12345"

user_password = input("Enter password: ")

if user_password == password:
    otp = random.randint(100000, 999999)
    print("Your OTP is:", otp)

    user_otp = input("Enter OTP: ")

    if user_otp == str(otp):
        print("Login Successful")
```

```
        else:
            print("Wrong OTP")
    else:
        print("Wrong Password")
```

- **Output:**

Enter password: 12345

Your OTP is: 456789

Enter OTP: 456789

Login Successful

Q - 4. Given an array of user objects with properties: username, isPremium, and lastLogin, write a function that returns only those users who are premium and have logged in within the last 7 days. Constraint: Assume lastLogin is a date string in 'YYYY-MM-DD' format, and today is '2024-06-10'.

- **Python Code:**

```
def filter_users(users):
    result = []

    for user in users:
        if user["isPremium"] == True and user["lastLogin"] >= "2024-06-03" and user["lastLogin"] <= "2024-06-10":
            result.append(user)

    return result

users = [
    {"username": "Amit", "isPremium": True, "lastLogin": "2024-06-08"},
    {"username": "Priya", "isPremium": False, "lastLogin": "2024-06-09"},
```

```
    {"username": "Rahul", "isPremium": True, "lastLogin": "2024-06-01"},
    {"username": "Neha", "isPremium": True, "lastLogin": "2024-06-05"}
]

print(filter_users(users))
```

- **Output:**

```
[
 {'username': 'Amit', 'isPremium': True, 'lastLogin': '2024-06-08'},
 {'username': 'Neha', 'isPremium': True, 'lastLogin': '2024-06-05'}
]
```

Q - 5. Use ChatGPT to generate a list of 5 common access control mistakes developers make in real-world apps like Instagram or Flipkart, and for each, write a one-line fix or prevention tip.

No.	Access Control Mistake	Prevention Tip
1	Weak Authentication	Use strong passwords and OTP verification.
2	Missing Authorization	Check user permissions before granting access.
3	Accessing Other Users' Data	Verify ownership of data before displaying it.
4	Excessive Permissions	Give users only the permissions they need.
5	Client-Side-Only Security	Always check permissions on the server.